Vendor Risk Summary: Tallgrass Cloud Analytics

FICTIONAL EXERCISE. The vendor and every answer in this summary were invented for a portfolio project. No real company is assessed.

Recommendation: do not approve as written. Approve only if the vendor accepts the five must have contract conditions below. The weighted score is Medium (45 percent), but the vendor fails a gating question: its standard terms give **7 days** to report a data incident, and we require **72 hours**. That alone makes the final rating **High**.

What we assessed

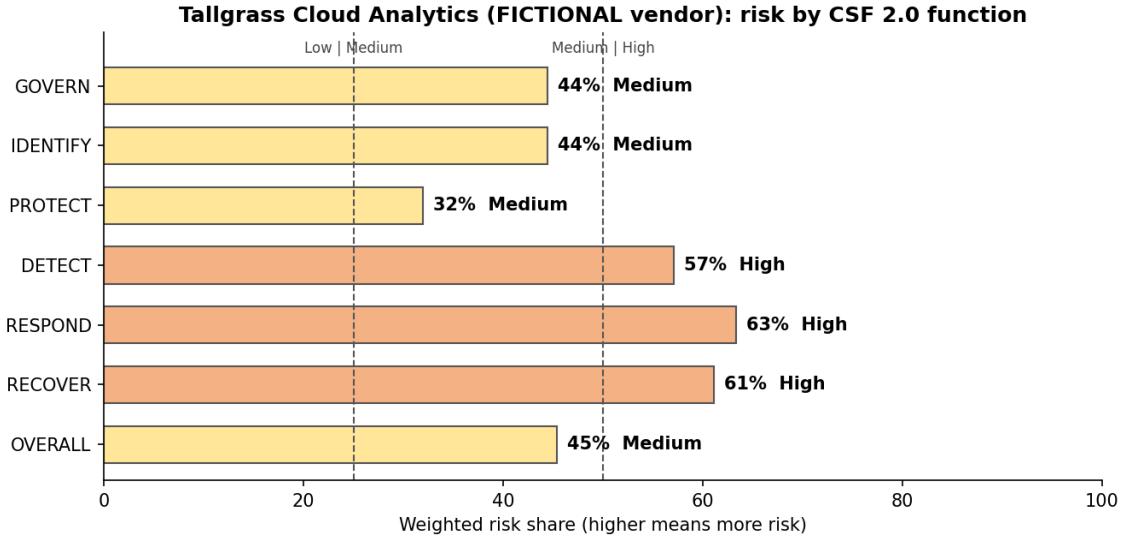
A 30 question security questionnaire across the six NIST CSF 2.0 functions. Each answer is scored 0 to 3 for risk, weighted by how much it matters to protecting our data. Four gating questions force a High rating if they score 3.

What the vendor does well

Customer data is encrypted at rest and in transit. Administrators must use multi factor authentication. Data stays in United States regions. Staff training is 98 percent complete and there is a public status page. These controls came with evidence.

Where the risk is

1. Incident notice. Seven days is too slow for us to meet our own notification duties.
2. No independent proof over time. Only a SOC 2 Type I report exists. The Type II report is not yet issued.
3. Recovery is untested. No restore test in the last 12 months, and the incident response plan was last exercised 18 months ago.
4. Exit. Deleting our data can take 90 days and no certificate is issued.
5. Fourth parties. Subprocessors are not listed or formally reviewed, and security logs are kept for only 30 days.



Invented vendor and answers. Scores are my own judgments using the published rubric. A gating failure on incident notice makes the final rating High.

Must have contract conditions

Clause	What we ask for
Incident notice	Notice within 72 hours of confirmation, a named contact and regular updates.
Independent assurance	SOC 2 Type II within 6 months, then every year. Right to terminate if it is late or qualified.
Right to audit	Annual evidence on request, and an independent assessor after any security incident.
Data return and deletion	Data returned in a usable format within 30 days, deleted within 30 more, with a signed certificate.
Subprocessors	Current list, 30 days notice of changes, and the same security terms passed down.

Scores are my own judgments using the published rubric, not measurements. This is not legal advice: clauses go to a lawyer before they go in a contract. A real assessment would also review the evidence itself.